

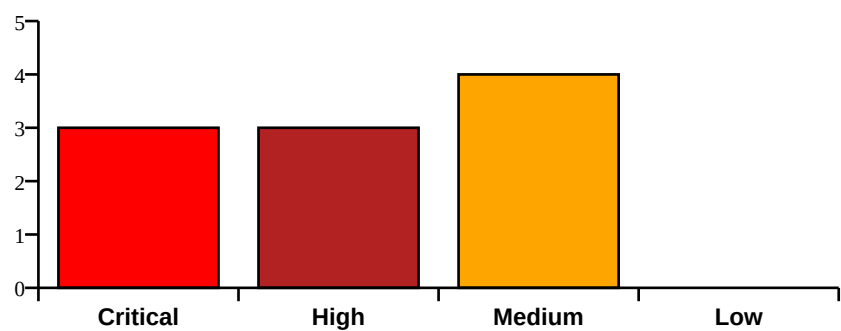
Vulnerability Scan Report

Target URL: http://localhost:3000
Generated (UTC): 2026-04-26 07:50:53Z

Summary

Metric	Count
Total Vulnerabilities	10
Critical Severity	3
High Severity	3
Medium Severity	4
Low Severity	0

Severity Distribution



Detailed Findings

1. Cryptographic Failure (High)

Location: http://localhost:3000

Evidence:

Application does not enforce HTTPS.

2. Cryptographic Failure (Medium)

Location: http://localhost:3000

Evidence:

Strict-Transport-Security header not set.

3. Identification & Authentication Failures (Medium)

Location: http://localhost:3000/#/login

Payload: token → Secure=False

Evidence:

Cookie transmitted without Secure flag.

4. Identification & Authentication Failures (Medium)

Location: http://localhost:3000/#/login

Payload: token → HttpOnly=False

Evidence:

Cookie accessible via JavaScript (XSS risk).

5. Identification & Authentication Failures (High)

Location: http://localhost:3000/#/login

Payload: exp field missing

Evidence:

JWT does not expire – can be reused indefinitely.

6. Identification & Authentication Failures (Critical)

Location: http://localhost:3000/#/login

Payload: data.password = 0192023a7bbd73250516f069df18b500

Evidence:

Sensitive data exposed inside JWT payload.

7. Identification & Authentication Failures (Critical)

Location: http://localhost:3000/#/login

Payload: data.deluxeToken =

Evidence:

Sensitive data exposed inside JWT payload.

8. Identification & Authentication Failures (Critical)

Location: http://localhost:3000/#/login

Payload: data.totpSecret =

Evidence:

Sensitive data exposed inside JWT payload.

9. Identification & Authentication Failures (Medium)

Location: http://localhost:3000/#/login

Payload: role = admin

Evidence:

User role exposed in JWT.

10. Identification & Authentication Failures (High)

Location: http://localhost:3000/#/login

Payload: Token stored in browser localStorage

Evidence:

Token accessible via JavaScript (XSS risk).

Activity Log

```
[07:50:30]
=====
[07:50:30] Starting Vulnerability Scan for http://localhost:3000
[07:50:30]
=====
[07:50:30] [*] Starting active crawl (mode=deep, headless=False)...
[07:50:31] [*] Attempting automatic login...
[07:50:31] [!] Active crawl error: You cannot call this from an async context - use a thread or sync_to_async.
[07:50:31] [*] Falling back to static crawl.
[07:50:31]
===== SCANNING http://localhost:3000 =====

[07:50:31] [INFO] Checking scheme → http
[07:50:31] [INFO] Initiating TLS handshake
[07:50:35] [SKIP] TLS check skipped → [WinError 10061] No connection could be made because the target machine
actively refused it
[07:50:35] [INFO] Checking cipher suite
[07:50:39] [SKIP] Cipher check skipped → [WinError 10061] No connection could be made because the target
machine actively refused it
[07:50:39] [INFO] Retrieving TLS certificate
[07:50:43] [SKIP] Certificate check skipped → [WinError 10061] No connection could be made because the target
machine actively refused it
[07:50:43] [HTTP] Checking HSTS header
[07:50:43] [HTTP] Response status → 200
[07:50:43] [HTTP] Response headers → {Access-Control-Allow-Origin: *, X-Content-
Type-Options: nosniff, X-Frame-Options: SAMEORIGIN, X-Feature-
Policy: payment;self;recruiting;/#/jobs;
Accept-Ranges: bytes, Cache-Control: public, max-age=0,
Last-Modified: Sun, 26 Apr 2026 05:45:49 GMT, ETag:
W/124fa-19dc8529929, Content-Type: text/html; charset=UTF-8,
Vary: Accept-Encoding, Content-Encoding: gzip,
Date: Sun, 26 Apr 2026 07:50:43 GMT, Connection: keep-alive,
Keep-Alive: timeout=5, Transfer-Encoding: chunked;}
[07:50:43] [SCAN] Scanning 1 URL(s) for sensitive data exposure...
[07:50:43] [SCAN] Checking http://localhost:3000 for sensitive data...
[07:50:43]
===== REPORT =====
[07:50:43] - [High] HTTPS not enforced
[07:50:43] - [Medium] HSTS header missing
[07:50:43]
===== SCORE =====
[07:50:43] Crypto Risk Score → 50/100
[07:50:43] Risk Level → MEDIUM
[07:50:46] [+] Looking for login form...
[07:50:49] [+] Found login form at http://localhost:3000/#/login
[07:50:49] [+] Login form detected dynamically.
[07:50:49] [+] Logging in with provided credentials...
[07:50:51] [+] Analyzing cookies...
[07:50:51] [!] Missing Secure flag on token
[07:50:51] [!] Missing HttpOnly flag on token
[07:50:51] [+] Analyzing JWT token...
[07:50:51] [+] JWT token found.
[07:50:51] [JWT HEADER] {
  "typ": "JWT",
  "alg": "RS256"
}
[07:50:51] [JWT PAYLOAD] {
  "status": "success",
  "data": {
    "id": 1,
    "username": "admin",
    "email": "admin@juice-sh.op",
    "password": "0192023a7bbd73250516f069df18b500",
    "role": "admin",
    "deluxeToken": "",
    "lastLoginIp": "",
    "profileImage": "assets/public/images/uploads/defaultAdmin.png",
    "totpSecret": "",
    "isActive": true,
    "createdAt": "2026-04-26 05:45:44.729 +00:00",
    "updatedAt": "2026-04-26 05:45:44.729 +00:00",
    "deletedAt": null
  },
  "iat": 1777189850
}
[07:50:53]
[*] Generating PDF report...
```